

AUTHORIZED SECURITY LAB DOSSIER

Legal Scope, Asset Inventory & Threat Model

Authorized • Isolated • Intentionally Vulnerable Security Testing Lab

1. Document Information

Field	Details
Project Name	Authorized Security Testing Lab
Document Purpose	Security assessment scope, asset inventory, threat model, and rules of engagement
Environment	Isolated intentionally vulnerable laboratory
Document Version	1.0
Assessor	[R.Aravinth]
Lab Owner	RabTech lab
Approval Date	9/2026

2. Purpose

The purpose of this engagement is to perform authorized security assessment activities against intentionally vulnerable laboratory systems. Testing is restricted to assets explicitly listed in the approved asset inventory. The engagement is designed to demonstrate controlled security testing, threat modeling, evidence handling, and reporting.

3. Authorization & Scope

Only the systems listed below are authorized for testing. Any system that is not explicitly

listed in the asset inventory is considered out of scope.

Asset ID	Asset	Address	Environment	Scope
LAB-01	Local Training Web Application	127.0.0.1:8080	Local Lab	In Scope
LAB-02	Deliberately Vulnerable VM	192.168.56.20	Isolated Lab	In Scope

4. Out-of-Scope Activities and Targets

Production systems and business-critical systems

Third-party systems and public Internet targets

Personal systems not included in the approved inventory

Any system not explicitly listed as an authorized asset

Denial-of-Service testing

Destructive payloads or destructive testing

Persistence mechanisms

Credential reuse against unauthorized accounts or systems

Uncontrolled data extraction

5. Asset Inventory

5.1 LAB-01 — Local Training Web Application

Field	Value
Asset ID	LAB-01
Type	Web Application

Address	127.0.0.1:8080
Environment	Local Lab
Owner	RabTech lab
Data	Test / Training Data
Primary Attack Surface	Web interface and application inputs
Scope	In Scope

5.2 LAB-02 — Deliberately Vulnerable VM

Field	Value
Asset ID	LAB-02
Type	Virtual Machine
Address	192.168.56.20
Environment	Isolated Lab
Owner	RabTech lab
Data	Test / Training Data

Primary Attack Surface	Network services and applications
Scope	In Scope

6. Data Classification & Evidence Handling

Data / Evidence	Classification	Handling Requirement
Test usernames	Internal / Test	Use only within the lab
Test credentials	Sensitive	Do not expose in public evidence
Application logs	Confidential	Store securely and retain only as needed
Screenshots / PoC evidence	Confidential	Redact secrets and personal information

Only the minimum evidence necessary to demonstrate a finding will be retained. Secrets and personal information must be redacted. Evidence retention and deletion must follow the agreed engagement requirements.

7. Trust Boundary & Data Flow

The engagement boundary separates the authorized laboratory environment from all systems outside the approved scope.

```

TESTER | v[ AUTHORIZED LAB BOUNDARY ] |-----| v          vLAB-01
LAB-02Web Application    Vulnerable VM127.0.0.1:8080    192.168.56.20

```

8. Data-Flow Diagram

```

Tester | | HTTP / authorized lab traffic v[ LAB-01 Web Application ] | v[ Application Data /
Storage ]Tester | | Isolated Lab Network v[ LAB-02 Vulnerable VM ] | v[ Network

```

Services / Test Data]

9. Attack Surface Inventory

Asset	Attack Surface	Assessment Focus
LAB-01	Authentication / Login	Authentication and session controls
LAB-01	Input fields	Input validation and application handling
LAB-01	URL parameters	Authorization and parameter handling
LAB-01	Sessions / Cookies	Session management
LAB-01	File upload (if present)	Validation and access controls
LAB-01	API (if present)	Authentication, authorization, and input handling
LAB-02	Network services	Service exposure and configuration
LAB-02	Authentication	Access controls
LAB-02	Installed applications	Configuration and security controls

10. STRIDE Threat Model

ID	STRIDE	Asset	Threat / Abuse Case	Risk	Mitigation
S-01	Spoofing	LAB-01	Unauthorized identity use	High	Strong authentication and session controls
T-01	Tampering	LAB-01	Unauthorized modification of application data	High	Server-side validation and authorization
R-01	Repudiation	LAB-01	Security-relevant actions are not adequately logged	Medium	Audit logging and monitoring
I-01	Information Disclosure	LAB-01	Sensitive information exposed through application behavior	High	Access controls and secure error handling
D-01	Denial of Service	LAB-01	Availability could be affected by resource exhaustion	High	Rate limiting and resource controls
E-01	Elevation of Privilege	LAB-02	Low-privilege user gains	High	Least privilege and

			unauthorized higher privileges		authorization checks
--	--	--	--------------------------------------	--	-------------------------

Note: Denial-of-Service is included as a threat-model scenario only. Active DoS testing is excluded from this engagement.

11. Risk Rating Method

Risk is documented using likelihood and impact as qualitative factors.

Likelihood	Impact	Example Risk
Low	Low	Low
Medium	Medium	Medium
High	High	High

Risk ratings in this dossier are assessment placeholders for the authorized lab and should be refined when actual lab evidence is available.

12. Rules of Engagement

12.1 Testing Window

Requirement	Value
Start Date / Time	[DD/MM/YYYY HH:MM]
End Date / Time	[DD/MM/YYYY HH:MM]
Emergency Contact	[Name / Contact]

Rate Limits	[Define safe limits for the lab]

12.2 Permitted Activities

Asset identification within the approved scope

Service identification within the authorized lab

Application security validation

Vulnerability verification using non-destructive methods

Evidence collection required for findings

Security documentation and reporting

12.3 Immediate Stop Conditions

Unexpected service disruption or instability

Contact with an out-of-scope system

Unexpected exposure of sensitive or personal information

Unexpected network traffic leaving the authorized lab

Risk of destructive impact

Testing window has expired

Lab owner or authorized contact requests testing to stop

13. Finding & Reporting Format

Field	Description
Finding ID	Unique identifier
Asset	Affected authorized asset
Title	Short description of the finding

Severity	Risk level and rationale
Description	What was identified
Reproduction	Authorized lab reproduction steps
Evidence	Minimum required evidence
Impact	Potential security impact
Remediation	Recommended corrective action

14. Assessment Workflow

1. Confirm authorization and scope
2. Validate the asset inventory
3. Map trust boundaries and data flows
4. Identify attack surfaces
5. Build and review the STRIDE register
6. Perform only permitted validation activities
7. Stop immediately if a stop condition occurs
8. Collect minimum necessary evidence
9. Document findings and remediation
10. Complete the final report

15. Approval

Role	Name	Signature	Date
Lab Owner	_____	_____	_____
Security Assessor	_____	_____	_____

16. Repository Notes

This repository contains documentation for an intentionally vulnerable, authorized

security testing laboratory. It is intended for defensive security learning, threat modeling, controlled validation, and professional security documentation.